



Vulnerability Assessment and Penetration Testing Report on Metasploitable 3

Introduction

This report presents the findings of a structured Vulnerability Assessment and Penetration Testing (VAPT) exercise conducted within a controlled lab environment. The objective was to identify security weaknesses in a simulated network and web application infrastructure, assess associated risks, and recommend appropriate remediation actions. The assessment followed the OWASP Web Security Testing Guide and NIST SP 800-115 methodologies. Testing was carried out using industry-standard open-source tools like Nikto and OpenVAS on Metasploitable

Nikto Web Server Scanning

Nikto is an open-source web server scanner used to detect potential vulnerabilities, misconfigurations, and outdated software on web servers. It checks for over 6,700 known issues including dangerous files, outdated server versions, and HTTP header problems.

Command used:

nikto -h 192.168.24.131 -o nikto_result.txt

- **-h (host)** — specifies the target IP address or hostname to scan. In this case it's scanning the machine at 192.168.24.131
- **-o (output)** — saves the scan results to a file named nikto_result.txt



```
(uddip@kali)-[~]
$ nikto -h 192.168.24.131 -o nikto_result.txt
- Nikto v2.5.0

-----
+ Target IP:      192.168.24.131
+ Target Hostname: 192.168.24.131
+ Target Port:    80
+ Start Time:     2026-04-21 03:58:07 (GMT-4)
-----
+ Server: Apache/2.4.7 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /: Directory indexing found.
+ Apache/2.4.7 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .
+ /./: Directory indexing found.
+ /./: Appending '/' to a directory allows indexing.
+ /./: Directory indexing found.
+ /: Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
+ /%2e/: Directory indexing found.
+ /%2e/: Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher. See: http://www.securityfocus.com/bid/2513
+ /::: Directory indexing found.
+ /?PageServices: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ /?wp-cs-dump: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ /phpmyadmin/changelog.php: Retrieved x-powered-by header: PHP/5.4.5.
+ /phpmyadmin/Changelog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /: Directory indexing found.
+ /: Abyss 1.03 reveals directory listing when multiple '/'s are requested. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2002-1078
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpmyadmin/: phpMyAdmin directory found.
+ /phpmyadmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpmyadmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ 8911 requests: 0 error(s) and 22 item(s) reported on remote host
+ End Time:      2026-04-21 03:58:31 (GMT-4) (24 seconds)
-----
+ 1 host(s) tested
```

Fig 1: Nikto Scan Result

OpenVAS

OpenVAS is a free, open-source vulnerability scanner integrated into Kali Linux via the GVM framework. It was used in this assessment to scan **Metasploitable 3** an intentionally vulnerable VM using the **Full and Fast** scan profile, testing against over **95,000 NVT plugins** to identify weaknesses across open ports and services.

Setup Testing Environment

A virtual lab was configured to safely simulate real-world attack scenarios:

- **Install OpenVAS:** Deploy Kali Linux as the attack platform and install openvas
- **Download Metasploitable 3:** Clone from github.com/rapid7/metasploitable3 and build with Vagrant.
- **Configure VirtualBox:** Place both VMs on an isolated Host-Only network. Assign static IPs to avoid DHCP conflicts



OpenVAS / GVM Full Installation

Step 1 Update System

```
sudo apt update && sudo apt upgrade -y
```

Step 2 Install GVM

```
sudo apt install gvm -y
```

Step 3 Run Initial Setup

```
sudo gvm-setup
```

This takes **15–30 minutes** it downloads all NVT plugins, SCAP data, and CERT data. Let it finish completely.

Step 4 Check Setup is Complete

```
sudo gvm-check-setup
```

All steps should show **OK**. If any show **ERROR**, follow the FIX instructions printed on screen.

Step 5 Start OpenVAS

```
sudo gvm-start
```

Step 6 Access Web Interface

Open your browser and go to: **https://127.0.0.1:9392**

Scan Target

To initiate a scan against the target machine, there are two approaches:

Manual Setup:

1. Navigate to **Configuration** → **Targets** and create a new target by entering the target IP address.
2. Go to **Scans** → **Tasks** and create a new task, linking it to the target created above.
3. Click the ► **Start** button to launch the scan immediately.

Quick Setup (Recommended for beginners): Alternatively, use the built-in **Task Wizard** simply enter the target IP address and GVM will automatically configure and launch the scan in one step.

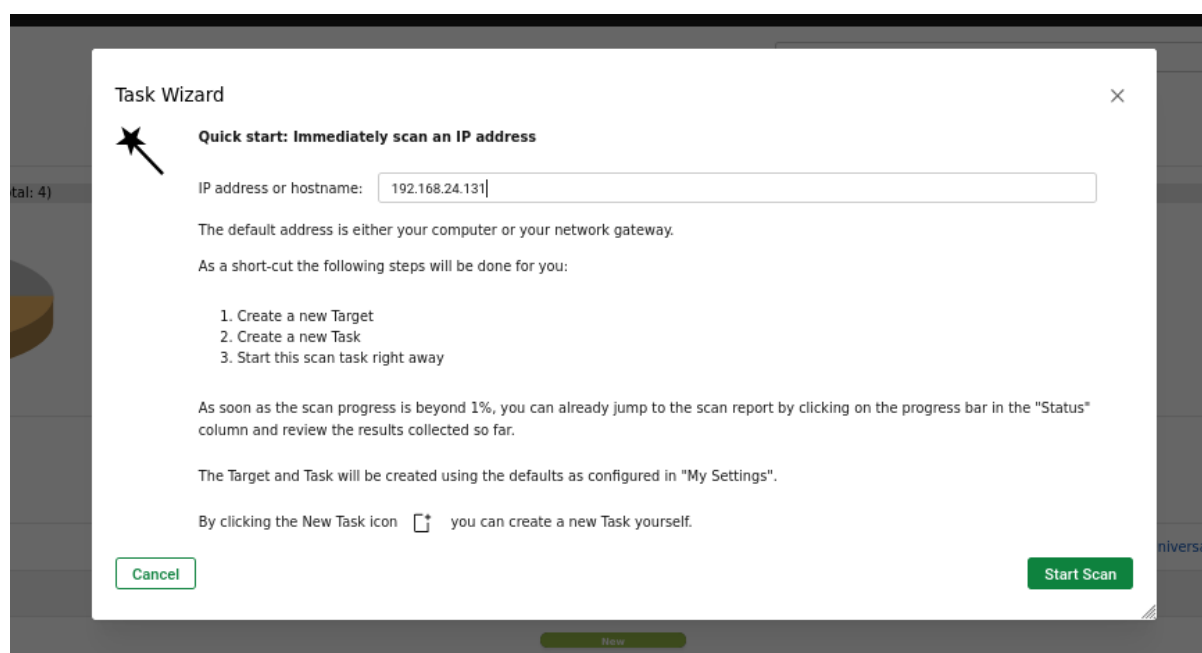


Fig2: Scanning Target via Task Wizard

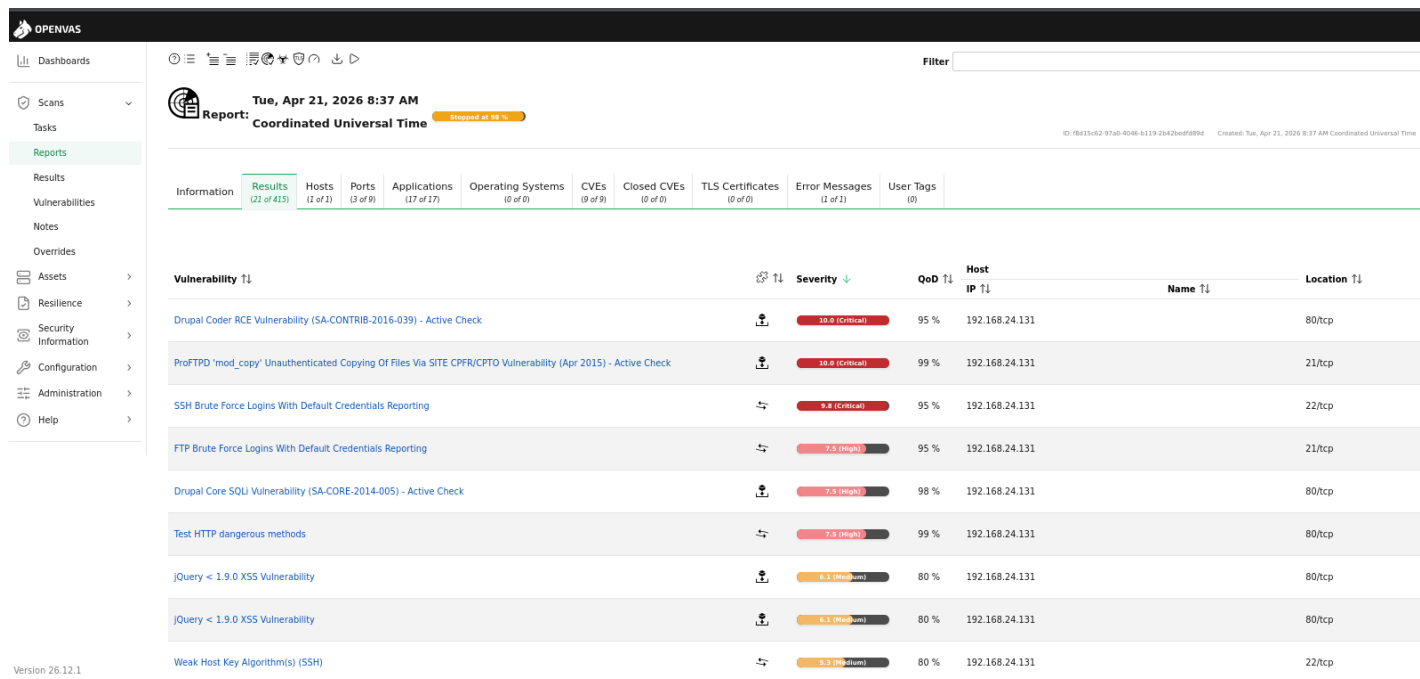


Fig 3: Scan Results

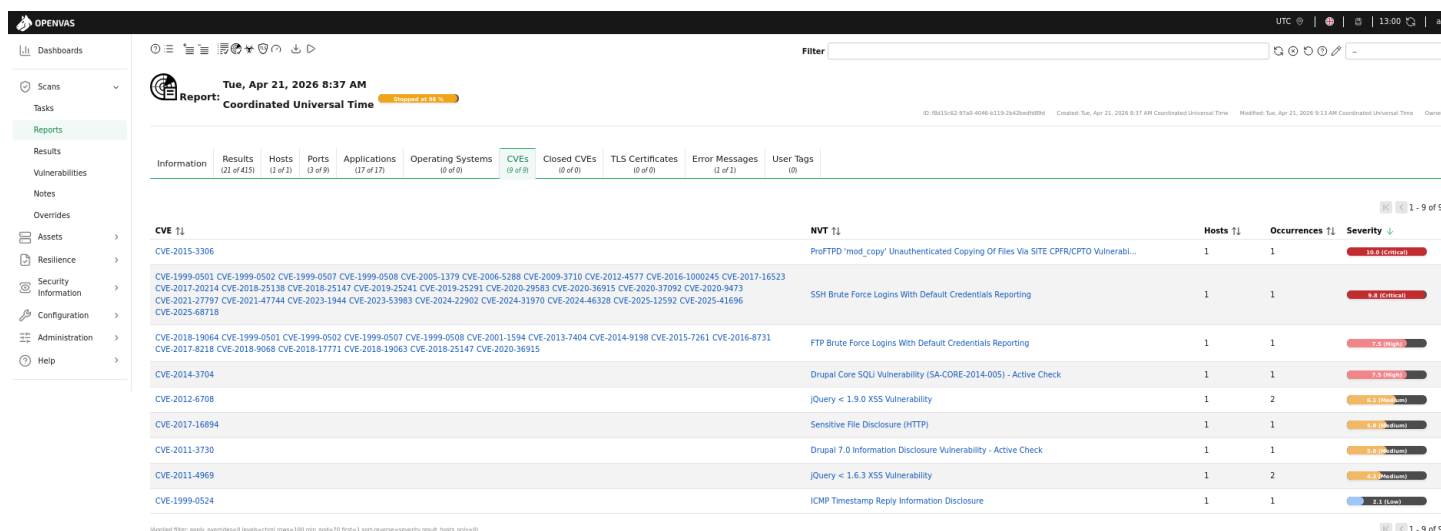


Fig 4: CVEs

Port	Hosts	Severity
21/tcp	1	10.0 (Critical)
80/tcp	1	10.0 (Critical)
22/tcp	1	9.8 (Critical)

Fig 5: PORTs



Risk Rating Methodology

Grade	Security	Criteria Description
A	Informational	This finding does not indicate vulnerability, but states a comment that notifies about design flaws and improper implementation that might cause a problem in the long run
B	Low	Minor vulnerabilities or weaknesses with limited impact and low exploitation probability. Often informational for defense hardening.
C	Medium	Vulnerabilities may not have public exploit (code) available or cannot be exploited in the wild
D	High	Vulnerabilities that could lead to sensitive data disclosure, privilege escalation, or significant impact on application security.
F	Critical	Vulnerabilities that allow complete system compromise, unauthorized administrative access, or significant data exposure with minimal effort

Summary of Findings

Severity	Critical	High	Medium	Low
Number of issues	2	2	8	1



Detailed Findings

Target

192.168.24.131

Total results

405

CVEs found

9

Scan date

Apr 21, 2026 —

All (13)

Critical (2)

High (2)

Medium (8)

Low (1)

#	Vulnerability	CVE	CVSS	Severity	Port
1	ProFTPD 'mod_copy' Unauthenticated File Copy	CVE-2015-3306	10.0	Critical	21/tcp
2	SSH Brute Force with Default Credentials	Multiple	9.8	Critical	22/tcp
3	FTP Brute Force with Default Credentials	Multiple	7.5	High	21/tcp
4	Drupal Core SQL Injection	CVE-2014-3704	7.9	High	80/tcp
5	jQuery < 1.9.0 XSS Vulnerability	CVE-2012-6708	6.1	Medium	80/tcp
6	Weak SSH Host Key Algorithm(s)	—	5.3	Medium	22/tcp
7	Weak SSH KEX Algorithm(s) Supported	—	5.3	Medium	22/tcp
8	Sensitive File Disclosure via HTTP	CVE-2017-16894	5.0	Medium	80/tcp
9	Drupal 7.0 Information Disclosure	CVE-2011-3730	5.0	Medium	80/tcp
10	FTP Unencrypted Cleartext Login	—	4.8	Medium	21/tcp
11	Cleartext Transmission of Data via HTTP	—	4.8	Medium	80/tcp
12	jQuery < 1.6.3 XSS Vulnerability	CVE-2011-4969	4.3	Medium	80/tcp
13	ICMP Timestamp Reply Information Disclosure	CVE-1999-0524	2.1	Low	—



Critical Findings

1. ProFTPD 'mod_copy' Unauthenticated File Copy

Risk	Critical 10
Reference No	CVE-2015-3306
Port	21
Vulnerability Description	The ProFTPD FTP server's mod_copy module allows unauthenticated users to copy files to any location on the server using SITE CPFR/CPTO commands. This can be exploited to place a web shell on the server
Remedies	Disable the mod_copy module in /etc/proftpd/proftpd.conf or upgrade ProFTPD to a patched version.

2. SSH Brute Force with Default Credentials

Risk	Critical 9.8
Port	22
Vulnerability Description	The SSH service accepted login using default or commonly known credentials. Successful brute force login grants full remote shell access to the target.
Remedies	Enforce strong password policy, disable root login over SSH, and implement fail2ban or key-based authentication only.

Conclusion

This VAPT exercise demonstrated the importance of a structured security assessment methodology when evaluating systems for vulnerabilities. By following the OWASP WSTG and NIST SP 800-115 frameworks and leveraging open-source tools like OpenVAS and Nikto, it was possible to conduct a thorough assessment without any commercial tooling. The lab environment confirmed the presence of several high-severity vulnerabilities in Metasploitable 3 highlighting the real-world consequences of poor patch management, weak authentication, and insufficient input validation.

All findings have been prioritised using CVSS v3.1 and mapped to a 3×3 risk matrix.